

CSI3015: Software Project Management

Risk Management

Dr. Keyur Joshi

Department of Software Engineering, Vellore Institute of Technology Vellore,
Tamilnadu 632014, India

September 11, 2026



VIT[®]
Vellore Institute of Technology
(Deemed to be University under section 3 of UGC Act, 1956)

Perspectives of Risk Management

- ▶ Risk management is not about avoiding projects with risks, but minimizing the impact of unforeseen events.
- ▶ **CEO N.R. Narayana Murthy (Infosys):** “Anything worth doing has risks. The challenge is effectively managing them through de-risking strategies”.
- ▶ Improper risk management and over-optimism are common sources of project failures (e.g., runaway projects, late delivery, budget overruns).
- ▶ A proactive perspective focuses on managing known risks versus ignoring unknown risks.

Risk Definition

- ▶ **Risk:** An uncertainty that can have a negative or positive effect on meeting project objectives.
- ▶ A probabilistic event—it may or may not occur.
- ▶ Not to be confused with normal project issues (e.g., finding bugs during testing is a certainty, not a risk).
- ▶ The goal of project risk management is to minimize potential negative risks while maximizing potential positive risks.

Risk Categories (Risk Breakdown Structure)

- ▶ **Business Risks:** Competitors, Suppliers, Cash flow, Market risks, Financial risks.
- ▶ **Technical Risks:** Hardware, Software, Network, New unproven technology.
- ▶ **Organizational Risks:** Executive support, User support, Team support.
- ▶ **Project Management Risks:** Estimates (Time/Cost), Communication, Resources.

Risk Assessment Approaches & Techniques

- ▶ **Goal:** Identify risks, analyze them, and prioritize them to determine where effort yields the most benefit.
- ▶ **Techniques for Identification:**
 - ▶ Brainstorming and meetings.
 - ▶ The Delphi technique (deriving consensus among experts anonymously).
 - ▶ Interviewing stakeholders.
 - ▶ Checklists based on historical data.
 - ▶ Root cause analysis (Fishbone diagrams).

Risk Analysis & Prioritization

- ▶ **Qualitative Risk Analysis:** Assessing likelihood and impact.
 - ▶ Probability/Impact Matrix.
 - ▶ Top Ten Risk Item Tracking.
- ▶ **Quantitative Risk Analysis:**
 - ▶ Expected Monetary Value (EMV) using Decision Trees.
 - ▶ Monte Carlo Analysis and Simulations.
 - ▶ Sensitivity Analysis.
- ▶ **Risk Exposure:** Computed using probability and impact to prioritize risks.

Risk Control: Planning & Resolution

- ▶ **Risk Management Planning:** Deciding how to approach risk management activities.
- ▶ **Risk Resolution/Response:**
 - ▶ *Negative Risks:* Avoidance, Acceptance, Transference, Mitigation.
 - ▶ *Positive Risks:* Exploitation, Sharing, Enhancement, Acceptance.
- ▶ **Contingency Plans:** Predefined actions taken if an identified risk event occurs.
- ▶ **Fallback Plans:** Used when attempts to reduce risk are ineffective.

Risk Control: Monitoring

- ▶ Continually gauging the status of risks and mitigation plans.
- ▶ **Risk Register:** A living document tracking identified risks, their probabilities, impacts, owners, and statuses.
- ▶ **Top Ten Risk Item Tracking:** Periodic management review of the project's most significant risks and trends over time.
- ▶ Reassessing risks as project phases change and external factors evolve.

Risk Retention & Risk Transfer

► Risk Retention (Acceptance):

- Accepting the consequences of a risk if it occurs.
- Handled by creating contingency reserves (time/money) or management reserves for unknown risks.
- Used when mitigation costs exceed potential risk impact.

► Risk Transfer:

- Shifting the consequence of a risk and management responsibility to a third party.
- Examples: Outsourcing, using Cloud Hosting SLAs, purchasing insurance.

Failure Mode and Effects Analysis (FMEA)

- ▶ A systematic, proactive method for evaluating a process to identify where and how it might fail.
- ▶ **Failure Modes:** What could go wrong?
- ▶ **Effects Analysis:** What would be the consequences of each failure?
- ▶ Analyzes system reliability by establishing severity and root causes.
- ▶ Helps build highly reliable software by mitigating critical failure paths.

Example 1: E-Commerce Payment Gateway

Component: Payment Processing API Integration

- ▶ **Potential Failure Mode:** API timeout during bank authorization.
- ▶ **Potential Effect(s):** Customer card is charged, but the order status fails or remains "Pending." Results in immediate customer frustration and support tickets.
- ▶ **Severity (S):** 8 (High financial and reputational impact)
- ▶ **Occurrence (O):** 4 (Intermittent network/third-party issues)
- ▶ **Detection (D):** 6 (Logged, but delayed alerting to the user)
- ▶ **Risk Priority Number (RPN):** $8 \times 4 \times 6 = 192$
- ▶ **Recommended Mitigation:** Implement automated transaction reconciliation, idempotent retry logic, and real-time user-facing status updates.

Example 2: User Authentication System

Component: Single Sign-On (SSO) Service

- ▶ **Potential Failure Mode:** Database connection pool exhaustion.
- ▶ **Potential Effect(s):** Complete system lockout. Legitimate users cannot access the platform, halting all user activity.
- ▶ **Severity (S):** 9 (Critical operational halt)
- ▶ **Occurrence (O):** 3 (Rare, usually only during unexpected traffic spikes)
- ▶ **Detection (D):** 2 (Easily and immediately detected by monitoring tools)
- ▶ **Risk Priority Number (RPN):** $9 \times 3 \times 2 = 54$
- ▶ **Recommended Mitigation:** Optimize database query efficiency, implement connection pooling limits, and set up auto-scaling for the authentication microservice.

Example 3: Cloud Data Migration

Component: Nightly Batch Data Transfer

- ▶ **Potential Failure Mode:** Silent data corruption during transit due to character encoding mismatch.
- ▶ **Potential Effect(s):** Analytics dashboards display garbage data; downstream machine learning models are trained on corrupted inputs.
- ▶ **Severity (S):** 7 (Significant impact on business intelligence)
- ▶ **Occurrence (O):** 5 (Common issue when integrating legacy systems)
- ▶ **Detection (D):** 8 (Hard to detect until a user manually spots the anomaly)
- ▶ **Risk Priority Number (RPN):** $7 \times 5 \times 8 = 280$ (**High Priority**)
- ▶ **Recommended Mitigation:** Add automated checksum validations, enforce strict UTF-8 encoding at the source, and implement data quality unit tests post-migration.

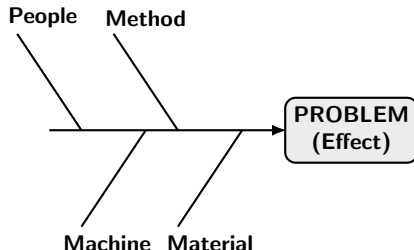
What is a Fishbone Diagram?

- ▶ Also called an **Ishikawa diagram**.
- ▶ Developed by **Kaoru Ishikawa**.
- ▶ Used for **Root Cause Analysis (RCA)**.
- ▶ Starts with an observed problem or “effect”.
- ▶ Possible causes are organized into logical categories.
- ▶ Causes can be progressively decomposed by asking:

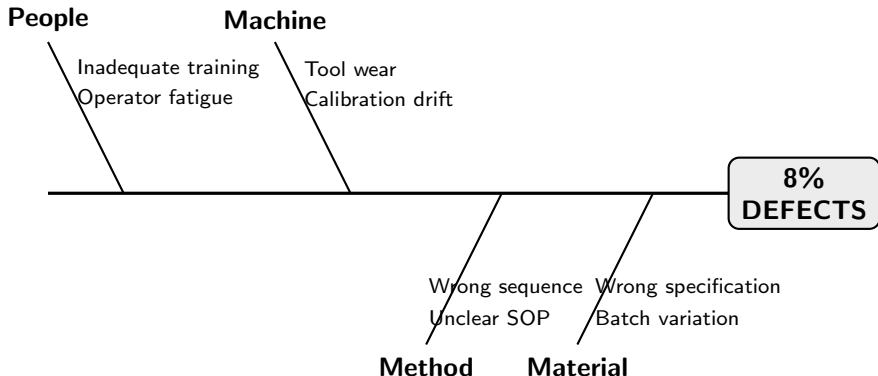
“Why?”

Important

A Fishbone diagram identifies **possible causes**; it does not by itself prove which cause is the root cause.



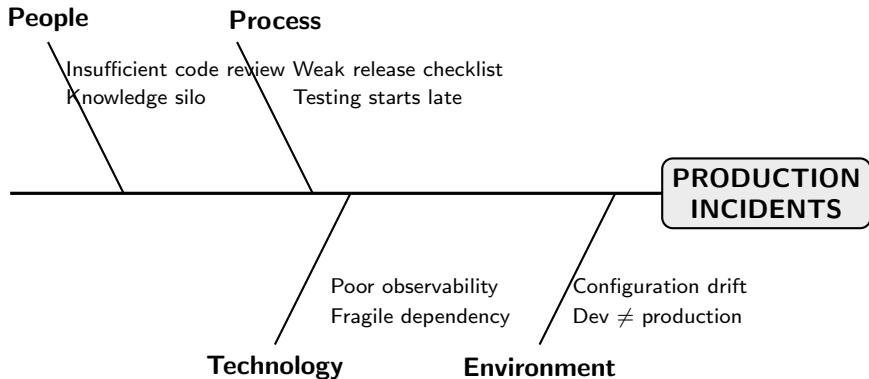
Example 1: Manufacturing – High Defect Rate



RCA Question

Which of these possible causes is supported by inspection data, measurements, or experiments?

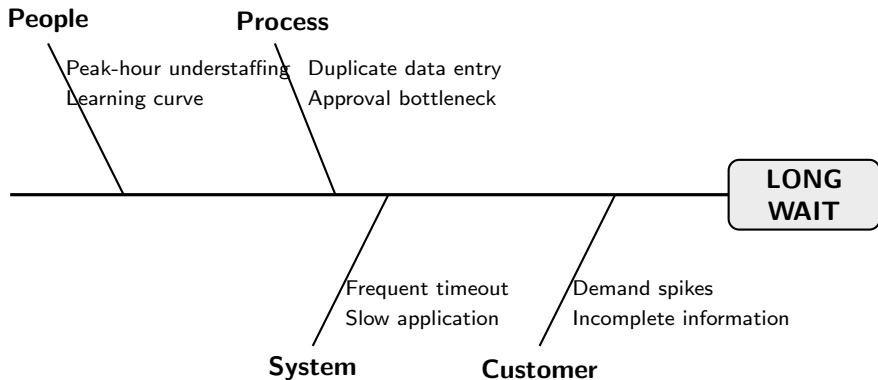
Example 2: Software Project – Production Failures



Example

Repeated production failures may have several contributing causes. The Fishbone diagram helps the team investigate them systematically.

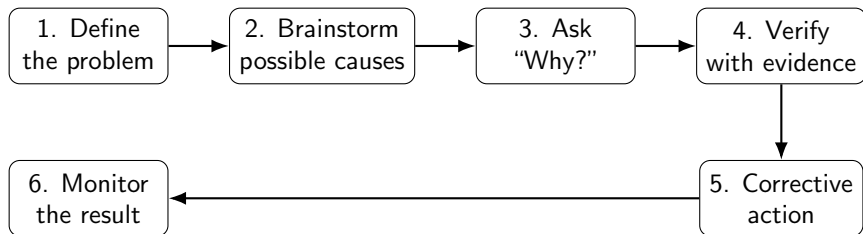
Example 3: Service – Long Customer Waiting Time



Observation

The categories need not always be “Man, Machine, Method, Material”. Choose categories that make sense for the problem being investigated.

From Fishbone to Verified Root Cause



Key Principle

A plausible cause is not necessarily the root cause.

The root cause should be supported by evidence and should explain the observed effect.

Useful evidence

Logs — Measurements — Inspection — Experiments

Operational Risks

- ▶ Risks arising from internal processes, people, and systems.
- ▶ Software failures affecting business operations (e.g., system downtime, data loss, process failures).
- ▶ Mitigation involves rigorous testing, establishing mature SDLC processes, and robust incident response plans.

Supply Chain Risk Management

- ▶ In modern software development, heavy reliance on third parties.
- ▶ **Dependencies:**
 - ▶ Open-source libraries and frameworks.
 - ▶ Third-party vendor dependencies.
 - ▶ Cloud infrastructure providers.
- ▶ **Management Strategies:** Evaluating vendor reliability, managing software component vulnerabilities, understanding supplier status.

Summary

- ▶ Software Project Management involves balancing scope, time, cost, and quality against continuous uncertainties.
- ▶ Proactive Risk Assessment (Identify, Analyze, Prioritize) and Control (Plan, Resolve, Monitor) are essential for success.
- ▶ Always maintain a living Risk Register and adapt strategies (Retain, Transfer, Mitigate, Avoid) as the project evolves.